

Tecnológico Nacional de México

Campus Saltillo

Ingeniería en Sistemas Computacionales

Cómputo en la nube

4.2 Demostrar la inyección SQL

Docente: Ing. Miguel Salazar del Bosque

Equipo:

Mauro Rodrigo Ruiz Alvarez 22050727

Viernes 20 de Marzo del 2026

Saltillo, Coahuila

Paso 1: Preparar el Entorno

```
Query OK, 1 row affected (0.014 sec)

MariaDB [vulnerable_db]> INSERT INTO usuarios (nombre_usuario, contrasena) VALUES ('user', 'password');
Query OK, 1 row affected (0.020 sec)

MariaDB [vulnerable_db]> select * from usuarios
-> ;
+-----+-----+-----+
| id | nombre_usuario | contrasena |
+-----+-----+-----+
| 1 | admin          | 1234       |
| 2 | user           | password   |
+-----+-----+-----+
2 rows in set (0.003 sec)

MariaDB [vulnerable_db]> _
```

```
mauro@debianhost: ~
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> CREATE DATABASE vulnerable_db;
Query OK, 1 row affected (0.008 sec)

MariaDB [(none)]> USE vulnerable_db;
Database changed
MariaDB [vulnerable_db]> CREATE TABLE usuarios (
  id INT AUTO_INCREMENT PRIMARY KEY,
  nombre_usuario VARCHAR(50),
  contrasena VARCHAR(50)
);
Query OK, 0 rows affected (0.118 sec)

MariaDB [vulnerable_db]> INSERT INTO usuarios (nombre_usuario, contrasena) VALUES ('admin', '1234');
Query OK, 1 row affected (0.014 sec)

MariaDB [vulnerable_db]> INSERT INTO usuarios (nombre_usuario, contrasena) VALUES ('user', 'password');
Query OK, 1 row affected (0.020 sec)

MariaDB [vulnerable_db]>
```

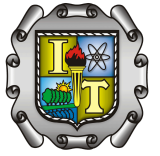
Paso 2: Crear la Aplicación Vulnerable

```
mauro@debianhost: ~
GNU nano 8.4 /var/www/html/login.php

<?php
$conn = new mysqli('192.168.56.107', 'root', '', 'vulnerable_db');
if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}

if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $usuario = $_POST['usuario'];
    $contrasena = $_POST['contrasena'];
    $sql = "SELECT * FROM usuarios WHERE nombre_usuario='$usuario' AND contrasena='$contrasena'";
    $result = $conn->query($sql);
    if ($result->num_rows > 0) {
        echo "Login exitoso";
    } else {
        echo "Credenciales inválidas";
    }
}

<form method="POST" action="login.php">
    Usuario: <input type="text" name="usuario"><br>
    Contraseña: <input type="password" name="contrasena"><br>
    <input type="submit" value="Ingresar">
</form>
```



Paso 3: Realizar la Inyección SQL

Login exitoso

Usuario:

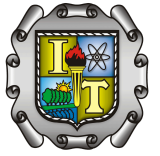
Contraseña:

Login exitoso

Usuario:

Contraseña:

Paso 4: Mitigación de la Inyección SQL



```
mauro@debianhost: ~
GNU nano 8.4 /var/www/html/login.php *
<?php
$conn = new mysqli('192.168.56.107', 'root', '', 'vulnerable_db');
if ($conn->connect_error) {
    die("Connection failed: " . $conn->connect_error);
}
if ($_SERVER['REQUEST_METHOD'] == 'POST') {
    $usuario = $_POST['usuario'];
    $contrasena = $_POST['contrasena'];
    $stmt = $conn->prepare("SELECT * FROM usuarios WHERE nombre_usuario=? AND contrasena=?");
    $stmt->bind_param("ss", $usuario, $contrasena);
    $stmt->execute();
    $result = $stmt->get_result();
    if ($result->num_rows > 0) {
        echo "Login exitoso";
    } else {
        echo "Credenciales inválidas";
    }
}
}
<form method="POST" action="login.php">
    Usuario: <input type="text" name="usuario"><br>
    Contraseña: <input type="password" name="contrasena"><br>
    <input type="submit" value="Ingresar">
</form>
```

Credenciales inválidas

Usuario:

Contraseña: